



PF2 AUDITORÍA DEL RGPD/RMS

Aspectos Sociales, Legales, Éticos y profesionales de la informática.

Convocatoria ordinaria.

Caso del concesionario.

Profesor asignado: RUBEN ZURITA HEVIA



10 DE MAYO DE 2026

DAVID RODRÍGUEZ CHANCA – UO289521- 7173819T

JAVIER GUTIÉRREZ ESQUINAS – UO289715- 32892688C

CARLOS CABRERA MORAL – UO288595- 71805515K

ESCUELA DE INGENIERÍA EN INFORMÁTICA DE OVIEDO || Curso 2025-2026

Hoja de Aclaraciones

**Q1: ¿Cómo se gestiona el acceso a los terminales de venta y al CRM?
¿Existen usuarios compartidos por departamento?**

A1: Cada empleado tiene su propio usuario nominal vinculado a su correo corporativo. No permitimos el uso de cuentas genéricas como "ventas" o "taller"; el sistema bloquea la sesión tras 5 minutos de inactividad.

Q2: Para la realización de una prueba de conducción (Test Drive), ¿qué procedimiento siguen para identificar al cliente?

A2: Escaneamos el DNI y el carné de conducir del cliente. Estos archivos se suben directamente a la ficha del cliente en el CRM y la copia física se destruye inmediatamente en una trituradora de papel.

Q3: En el caso de solicitudes de financiación, ¿cómo se envían las nóminas y datos bancarios a la entidad financiera?

A3: Se hace a través de los portales seguros B2B de las financieras (como Volkswagen Financial Services). Nunca se envían documentos sensibles por correo electrónico convencional sin cifrar.

Q4: ¿Dónde se encuentran alojados los servidores y las bases de datos de clientes?

A4: Utilizamos una solución en la nube proporcionada por el fabricante y un ERP propio alojado en Microsoft Azure, con centros de datos situados dentro del territorio de la Unión Europea.

Q5: ¿Cómo y dónde se almacenan los contratos de compraventa y laborales originales en formato papel?

A5: Se guardan en un archivo centralizado en el despacho de administración, dentro de armarios ignífugos con llave. Solo el gerente y el jefe de administración tienen copia de esa llave.

Q6: ¿Cuál es la política de copias de seguridad de la empresa?

A6: El sistema realiza backups incrementales automáticos cada noche en la nube y una copia completa semanal que se replica en un servidor físico externo a la sede principal.

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 1 de 20	



Q7: Respecto a la videovigilancia, ¿cuánto tiempo conservan las imágenes y quién puede verlas?

A7: Las imágenes se borran automáticamente a los 30 días, tal como marca la ley. Solo el responsable de seguridad tiene acceso a la visualización de las grabaciones mediante contraseña.

Q8: ¿Reciben los empleados alguna formación específica sobre el RGPD?

A8: Sí, todos los comerciales y el personal de taller reciben un curso de formación inicial sobre protección de datos y firman una cláusula de confidencialidad al incorporarse.

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 2 de 20	



Índice

1. Informe de Auditoría	4
1.1 Alcance	4
1.1.1 Objeto	4
1.1.2 Normativa	4
1.1.3 Fecha de la auditoría	4
1.1.4 Identificación del responsable del tratamiento.....	4
1.2 Situación Actual.....	5
1.2.1 Actividad de la empresa	5
1.2.2 Organización y equipamiento.....	5
1.2.3 Gestión de información	6
1.3 Ficheros objeto de la auditoria	7
1.3.1 Clasificación de los ficheros	7
1.3.2 Solicitud de inscripción del fichero en la AEPD.....	8
1.4 Dictamen de adecuación de medidas y controles.....	9
1.4.1 Documento de seguridad	9
1.4.2 Funciones y obligaciones del personal	10
1.4.3 Registro de incidencias.....	12
1.4.4 Identificación y Autenticación	12
1.4.5 Control de Acceso.....	13
1.4.6 Gestión de Soportes y Documentos	14
1.4.7 Copias de Respaldo y Recuperación.....	14
1.4.8 Registro de Accesos (Nivel Medio/Alto)	15
1.4.9 Redes de Comunicaciones	15
1.4.10 Encargado de Tratamiento	16
1.5 Lugar de trabajo	16
1.6 Documentación entregada.....	17
1.7 Conclusión	18
2. ANEXOS.....	20
2.1 Bibliografía.....	20

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 3 de 20	



1. Informe de Auditoría

1.1 Alcance

1.1.1 Objeto

El propósito de este informe es cumplir con la solicitud de la empresa **Motor Astur S.L.** de llevar a cabo una auditoría de seguridad y cumplimiento sobre el tratamiento de datos personales en el marco del **Reglamento General de Protección de Datos (RGPD)**. La auditoría se centra específicamente en la sede principal y el taller oficial ubicado en Asturias.

1.1.2 Normativa

Se han considerado las siguientes regulaciones como referencia de cumplimiento técnico y legal:

- **Reglamento (UE) 2016/679 (RGPD).**
- **Ley Orgánica 3/2018 (LOPDGDD).**
- **R.D. 1720/2007 (RMS), aplicado para la determinación técnica de medidas de seguridad.**

1.1.3 Fecha de la auditoría

La auditoría se realiza el día 10/05/2026.

1.1.4 Identificación del responsable del tratamiento

NOMBRE	MOTOR ASTUR S.L.
NIF	B74395179
DIRECCIÓN	AVENIDA VIELLA, 40-33420. SIERO
TELÉFONO	985 79 19 09
EMAIL DPO	autosalon@grupoautosalon.es

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 4 de 20	

1.2 Situación Actual

1.2.1 Actividad de la empresa

Motor Astur S.L. es un concesionario oficial de automóviles ubicado en Siero, Asturias, perteneciente al Grupo Autosalón. Su actividad principal comprende la compraventa de vehículos nuevos y de ocasión, la gestión de financiación y la prestación de servicios de mantenimiento a través de su taller oficial, actuando como distribuidor autorizado de las marcas Volkswagen e Hyundai.

La empresa trata datos personales de clientes, empleados y terceros colaboradores como gestorías y entidades financieras, con distintos niveles de acceso según el perfil del trabajador: equipo comercial, administración y taller mecánico.

1.2.2 Organización y equipamiento

La infraestructura tecnológica de la organización se ha diseñado para soportar la movilidad de la fuerza de ventas y la operatividad del taller.

- **Hardware:**
 - **Estaciones de trabajo:** 12 portátiles (HP ProBook) para el equipo comercial y 3 terminales de sobremesa en el área de administración.
 - **Movilidad en Taller:** 4 tablets (Samsung Galaxy Tab) utilizadas para la recepción activa de vehículos y firma digital de órdenes de reparación.
 - **Infraestructura de Servidores:** Un servidor físico local (Dell PowerEdge) para el controlador de dominio y almacenamiento de archivos compartidos, además de un servidor NAS (Synology) para copias de seguridad locales.
- **Software:**
 - **ERP/CRM:** Uso de la plataforma "GestMotor 360", sistema especializado en automoción que centraliza las ventas, el stock y el taller.
 - **Ofimática:** Microsoft 365 para la gestión de correo electrónico corporativo y colaboración documental.

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 5 de 20	

- **Sistemas Auxiliares:** Conectores B2B con plataformas de fabricantes (VW Group / Hyundai) y pasarelas de financiación bancaria.
- **Red y Comunicaciones:**
 - **Acceso a Internet:** Conexión mediante fibra óptica simétrica de 1 Gbps.
 - **Infraestructura Wireless:** Red Wi-Fi profesional con segmentación mediante VLANs. Existe una red privada para empleados con autenticación WPA3 y una red de invitados (Guest) aislada físicamente de la red de gestión.

1.2.3 Gestión de información

- **Entrada de Datos (Ingesta):** Los datos se recaban por tres vías: formularios web (leads), entrada física en exposición (escaneo de DNI/Permiso de conducir) y recepción en taller (vinculación de matrícula a titular).
- **Tratamiento y Almacenamiento:** La información se vuelca en el ERP GestMotor. Los documentos físicos sensibles (nóminas para financiación) se digitalizan y el original se custodia temporalmente antes de su destrucción.
- **Cesión a Terceros:** Durante el proceso de venta, los datos fluyen externamente hacia:
 - **Entidades Financieras:** Para el estudio de riesgos.
 - **DGT / Gestoría:** Para la tramitación administrativa del vehículo.
 - **Fabricantes:** Para el registro de garantías oficiales.
 - **Consultora Pérez:** Para la realización de nóminas.
- **Explotación y Mantenimiento:** Los datos permanecen activos en el CRM para recordatorios de revisiones legales (ITV) y mantenimiento preventivo.
- **Archivo y Destrucción:** Una vez finalizada la relación contractual, los datos pasan a un estado de bloqueo durante los plazos legales prescritos (5 años con carácter general y 10 años por normativa de prevención de blanqueo de capitales en transacciones de alto valor).

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 6 de 20	

1.3 Ficheros objeto de la auditoría

1.3.1 Clasificación de los ficheros

1.3.1.1 Fichero de Clientes y Taller (Digital)

- **Ubicación:** Base de datos del ERP "GestMotor 360".
- **Finalidad:** Gestión de procesos de compraventa, facturación, seguimiento de garantías y registro de mantenimientos técnicos.
- **Nivel de Seguridad: MEDIO.**
- **Contenido:** Datos identificativos (DNI, nombre), datos de contacto, información financiera (cuentas bancarias), y datos técnicos del vehículo (matrícula, bastidor).

1.3.1.2 Fichero de Recursos Humanos y Nóminas (Digital)

- **Ubicación:** Servidor local y conexión con consultora Pérez.
- **Finalidad:** Gestión del personal, pago de salarios, cumplimiento de obligaciones de Seguridad Social y prevención de riesgos laborales.
- **Nivel de Seguridad: MEDIO.**
- **Contenido:** DNI, datos de contacto, historial laboral, titulación, salarios y datos bancarios para el abono de nóminas.

1.3.1.3 Fichero de Videovigilancia (Digital/Vídeo)

- **Ubicación:** Grabador digital (NVR) con acceso restringido.
- **Finalidad:** Garantizar la seguridad física de las instalaciones, vehículos en stock y protección del personal y clientes.
- **Nivel de Seguridad: MEDIO.**
- **Contenido:** Grabación de imágenes y, en su caso, audio en zonas autorizadas del establecimiento.

1.3.1.4 Fichero Físico de Contratos (Papel)

- **Ubicación:** Armarios ignífugos en el despacho de administración.
- **Finalidad:** Custodia de originales de contratos de compraventa, documentos de financiación y expedientes de personal.
- **Nivel de Seguridad: BÁSICO.**
- **Contenido:** Copias de DNI, firmas manuscritas, contratos laborales y documentos notariales.

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 7 de 20	

1.3.2 Solicitud de inscripción del fichero en la AEPD

Tal y como se describe en la normativa vigente, desde el 25 de mayo de 2018 se sustituye la necesidad de inscribir ficheros ante la Agencia Española de Protección de Datos (AEPD) por la elaboración de un **Registro de Actividades de Tratamiento (RAT)**. Este registro debe contener la información señalada en el artículo 30 del Reglamento General de Protección de Datos (RGPD).

Dicho registro debe recoger obligatoriamente los siguientes aspectos:

- Nombre y datos de contacto del responsable y, en su caso, del delegado de protección de datos (DPO).
- Finalidad del tratamiento.
- Descripción de las categorías de interesados y de las categorías de datos personales tratados.
- Categorías de destinatarios a quienes se comunicaron o comunicarán los datos, incluyendo terceros países.
- Cuando sea posible, los plazos previstos para la supresión de las diferentes categorías de datos.
- Una descripción general de las medidas técnicas y organizativas de seguridad aplicadas.

De esta manera, se plantea el siguiente registro detallado por actividades principales

1.3.2.1 Gestión de clientes y Taller.

ACTIVIDAD	GESTIÓN DE CLIENTES Y TALLER
FINALIDAD	Almacenar y tratar la información necesaria para la compraventa de vehículos, gestión de garantías, matriculación y el histórico de mantenimientos técnicos en taller.
INTERESADOS	Clientes (personas físicas), Propietarios de vehículos, Motor Astur Group S.A.
CATEGORÍA	Datos identificativos (DNI, firma), Datos de contacto, Datos financieros (cuentas bancarias), Datos técnicos (matrícula, bastidor).

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 8 de 20	

PLAZO CONSERVACIÓN	10 años desde la última transacción (por imperativo legal de la normativa de prevención de blanqueo de capitales y fiscalidad).
---------------------------	--

1.3.2.2 Gestión de Recursos Humanos

ACTIVIDAD	GESTIÓN DE EMPLEADOS
FINALIDAD	Gestión de nóminas, contratos laborales, formación en prevención de riesgos y control horario del personal del concesionario.
INTERESADOS	Empleados, Dirección de Motor Astur Group, Consultoría Pérez.
CATEGORÍA	Datos identificativos, Datos bancarios, Número de la Seguridad Social, Formación/Titulación académica.
PLAZO CONSERVACIÓN	Mientras dure la relación laboral y hasta 5 años después de su extinción para cubrir responsabilidades legales.

1.3.2.3 Gestión del catálogo online

ACTIVIDAD	GESTIÓN DEL CATÁLOGO ONLINE
FINALIDAD	Publicación y mantenimiento del catálogo de vehículos en línea.
INTERESADOS	Clientes potenciales, visitantes web.
CATEGORÍA	Datos de contacto (leads), datos de navegación.
PLAZO CONSERVACIÓN	Hasta retirada del vehículo o baja del lead.

1.4 Dictamen de adecuación de medidas y controles

1.4.1 Documento de seguridad

Este instrumento constituye el pilar organizativo de la empresa. Consiste en un registro detallado que describe la arquitectura de los sistemas de información, los protocolos de actuación del personal y las medidas técnicas implementadas para salvaguardar la integridad de los datos personales.

Referencia Normativa:

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 9 de 20	

- **Artículo 88 del R.D. 1720/2007 (RMS):** Establece el contenido mínimo obligatorio del documento.
- **Artículo 32 del RGPD:** Obliga a mantener medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.

Hechos y Observaciones	Dictamen de Cumplimiento
Se confirma la existencia de un manual interno de protección de datos.	Parcial
El inventario de recursos protegidos no ha sido actualizado desde la implantación de las tablets en la recepción activa de taller.	Incumplimiento
El documento no especifica el tratamiento de datos derivados de la conexión B2B con las financieras externas.	Incumplimiento

Medidas Correctoras:

- **Actualización del Inventario:** Incluir de forma exhaustiva todos los dispositivos móviles (tablets y portátiles comerciales) y los sistemas de almacenamiento en la nube (*Cloud*) contratados.
- **Auditoría de Versiones:** Establecer un procedimiento de revisión semestral que garantice que cualquier cambio en la infraestructura técnica quede reflejado en el documento.

1.4.2 Funciones y obligaciones del personal

Control orientado a garantizar que todo empleado con acceso a datos de carácter personal comprenda sus responsabilidades, el límite de sus autorizaciones y el deber de confidencialidad que le asiste.

Referencia Normativa:

- **Artículo 89 del R.D. 1720/2007:** Exige la definición clara de perfiles de usuario y obligaciones de control.

Verificación de Cumplimiento en Motor Astur: Tras las entrevistas con el personal de ventas y postventa, se detecta que, si bien el personal administrativo tiene claras sus funciones y los comerciales de vehículos de ocasión también tienen claras sus funciones, no existe constancia de que los mecánicos del taller

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 10 de 20	



hayan sido instruidos sobre la privacidad de los datos de geolocalización contenidos en los sistemas de diagnóstico de los vehículos.

Medidas Correctoras:

- **Circular Técnica:** Notificar por escrito al taller la prohibición de uso de datos GPS fuera de la diagnosis técnica.
- **Anexo Contractual:** Firma de compromiso de confidencialidad específico sobre datos de telemetría del cliente.

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 11 de 20	

1.4.3 Registro de incidencias

Definición: Procedimiento operativo para identificar, notificar y subsanar cualquier quiebra de seguridad que afecte a los datos. Este registro es la base para cumplir con la obligación de notificar a la AEPD en caso de riesgos para los derechos y libertades de los interesados.

Referencia Normativa:

- **Artículo 90 del R.D. 1720/2007:** Define la obligatoriedad y el contenido del registro.
- **Artículos 33 y 34 del RGPD:** Establecen los plazos (72 horas) y la forma de notificación de brechas de seguridad.

Verificación de Cumplimiento en Motor Astur: Se observa que la empresa registra únicamente errores de *hardware* o caídas de red local a través de su servicio técnico externo, omitiendo incidencias relacionadas con la privacidad (ej. extravío de una fotocopia de DNI o acceso no autorizado al CRM). El actual "libro de registro" es insuficiente al no contemplar los efectos derivados de la incidencia ni las medidas aplicadas para mitigar el daño.

Medidas Correctoras: Implementar de forma obligatoria el siguiente sistema de registro de incidencias lógicas y físicas:

Campo Obligatorio	Propósito del Control
Identificación de la Brecha	Describir si es un fallo de confidencialidad, integridad o disponibilidad.
Cronología	Registrar fecha de producción y fecha de detección (clave para el plazo de 72h del RGPD).
Efectos y Gravedad	Evaluación del impacto potencial sobre los clientes (bajo, medio, alto).
Medidas Aplicadas	Acciones técnicas y organizativas para neutralizar la incidencia y evitar su repetición.

1.4.4 Identificación y Autenticación

Mecanismo diseñado para garantizar que solo los usuarios autorizados accedan a los activos de información mediante una identidad inequívoca. El control debe cubrir tanto la creación de credenciales como su gestión segura. **Referencia**

Normativa:

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 12 de 20	

- **Artículos 93 y 98 del R.D. 1720/2007:** Exigen medidas para la correcta identificación de usuarios y límites a los intentos de acceso no autorizados.

Verificación de Cumplimiento en Motor Astur: Se observa que el personal utiliza contraseñas con un nivel de robustez bajo y no existe un mecanismo técnico que impida el acceso tras reiterados intentos fallidos. Además, se ha detectado el uso de un usuario genérico en el equipo comercial, a pesar de lo manifestado por la dirección en la fase de entrevistas (Q1/A1), la inspección técnica reveló la existencia de un usuario compartido en el equipo comercial, lo que contradice la política declarada, impidiendo la trazabilidad individual exigida por la normativa.

Medidas Correctoras:

- **Individualización de accesos:** Eliminar de inmediato el usuario genérico del equipo comercial y asignar cuentas nominales a cada empleado para garantizar la trazabilidad.
- **Política de contraseñas:** Implementar requisitos técnicos de complejidad (mínimo 8 caracteres, uso de mayúsculas, números y símbolos) y forzar la caducidad periódica.
- **Control de intentos:** Configurar el sistema para bloquear el acceso tras tres intentos fallidos de autenticación.

1.4.5 Control de Acceso

Conjunto de medidas técnicas y físicas destinadas a restringir el uso de recursos lógicos y espacios protegidos exclusivamente al personal habilitado para el desempeño de sus funciones. **Referencia Normativa:**

- **Artículos 91 y 99 del R.D. 1720/2007:** Regulan el acceso a recursos del sistema y la protección física de los equipos e instalaciones.

Verificación de Cumplimiento en Motor Astur: Los contratos físicos de compraventa se almacenan en archivadores dentro de armarios que disponen de sistema de cierre bajo llave.

Medidas Correctoras:

- **Gestión de llaves:** Limitar la custodia de las llaves exclusivamente al personal autorizado en el documento de seguridad.

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 13 de 20	

1.4.6 Gestión de Soportes y Documentos

Procedimientos para el inventariado, etiquetado, traslado y eliminación segura de cualquier medio que contenga datos de carácter personal, ya sea físico o digital.

Referencia Normativa:

- **Artículos 92 y 97 del R.D. 1720/2007:** Establecen las pautas para la identificación, entrada y salida de soportes de información.

Verificación de Cumplimiento en Motor Astur: La empresa asegura que la eliminación de papel se realiza mediante triturado mecánico antes de ser desechado. Sin embargo, se ha constatado que los documentos almacenados en los puestos de trabajo comerciales carecen de medidas de protección lógica adicionales y no se aplica un sistema de nomenclatura que dificulte la identificación del contenido por terceros.

Medidas Correctoras:

- **Protección lógica:** Implementar el cifrado de archivos locales en los terminales comerciales y el uso de contraseñas de apertura para documentos sensibles.
- **Nomenclatura segura:** Adoptar un sistema de nombres de archivo basado en códigos internos que no revelen la identidad del cliente o el contenido del documento a simple vista.

1.4.7 Copias de Respaldo y Recuperación

Protocolos operativos para asegurar la integridad y reconstrucción de la información ante fallos del sistema o desastres, garantizando que los datos puedan restaurarse a su estado original. **Referencia Normativa:**

- **Artículo 94 del R.D. 1720/2007:** Define la periodicidad mínima semanal y la obligación de verificar los procedimientos semestralmente.

Verificación de Cumplimiento en Motor Astur: El concesionario realiza copias de seguridad mediante copias incrementales automáticas nocturnas y una copia completa semanal replicada en el servidor de la consultora. A pesar de ello, no se han encontrado evidencias documentales que certifiquen que el responsable del tratamiento verifique cada seis meses la efectividad y la correcta restauración de dichas copias.

Medidas Correctoras:

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 14 de 20	

- **Plan de verificación:** Establecer un calendario de pruebas de restauración semestrales para asegurar que las copias alojadas por la consultora son íntegras y funcionales.
- **Evidencia documental:** Crear un registro de control donde el responsable del tratamiento firme y valide cada prueba de recuperación realizada

1.4.8 Registro de Accesos (Nivel Medio/Alto)

Sistema de auditoría que documenta de forma persistente qué usuario accede a qué información, indicando la fecha, la hora y el tipo de operación realizada.

Referencia Normativa:

- **Artículo 103 del R.D. 1720/2007:** Obliga a conservar este registro durante dos años y a ser revisado mensualmente por el responsable de seguridad.

Verificación de Cumplimiento en Motor Astur: Se ha constatado que no existe un registro automatizado de los accesos a los ficheros con datos bancarios de los clientes o nóminas de empleados. La trazabilidad es inexistente para los accesos lógicos al ERP, lo que vulnera los requisitos exigibles para tratamientos de nivel de seguridad medio y alto.

Medidas Correctoras:

- **Activación de Logs:** Configurar el ERP y los sistemas de archivos para registrar automáticamente la ID de usuario, fecha, hora, archivo accedido y tipo de operación (lectura/escritura).
- **Revisión mensual:** El responsable de seguridad deberá revisar los informes de control mensualmente para detectar posibles anomalías.

1.4.9 Redes de Comunicaciones

Medidas de seguridad aplicadas a la transmisión de datos personales para evitar que la información sea interceptada o manipulada por terceros ajenos a la organización.

Referencia Normativa:

- **Artículos 85 y 104 del R.D. 1720/2007:** Exigen niveles de seguridad locales y el uso de cifrado en la transmisión por redes públicas o inalámbricas.

Verificación de Cumplimiento en Motor Astur: El concesionario utiliza una infraestructura de fibra óptica para la comunicación externa. No obstante, se ha detectado que la información recopilada mediante formularios web no especifica

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 15 de 20	

el uso de protocolos de cifrado robustos durante su tránsito hacia el servidor de la empresa.

Medidas Correctoras:

- **Cifrado en tránsito:** Implementar protocolos **SSL/TLS (HTTPS)** en todos los formularios de la página web para garantizar que el envío de datos desde el cliente al servidor sea ininteligible para terceros.
- **Seguridad inalámbrica:** Asegurar que las transmisiones vía Wi-Fi para uso administrativo utilicen cifrado robusto (WPA3).

1.4.10 Encargado de Tratamiento

Regulación de los servicios prestados por terceros que impliquen acceso a datos personales del concesionario, asegurando que estos apliquen las mismas garantías de seguridad. **Referencia Normativa:**

- **Artículo 82 del R.D. 1720/2007:** Detalla las responsabilidades del encargado y la obligación de formalizar un contrato.

Verificación de Cumplimiento en Motor Astur: La empresa cuenta con colaboradores externos como la "Consultoría Pérez" para la gestión de nóminas y "AsturWeb" para la administración del catálogo online. No se ha podido verificar la existencia de un procedimiento que compruebe si estas terceras empresas aplican medidas de seguridad equivalentes a las exigidas por Motor Astur.

Medidas Correctoras:

- **Diligencia debida:** Solicitar formalmente a la "Consultoría Pérez" y "AsturWeb" su propio documento de seguridad y certificados de cumplimiento para verificar que sus estándares son equivalentes a los de Motor Astur.
- **Formalización contractual:** Asegurar que los contratos de prestación de servicios incluyan las cláusulas específicas de seguridad y la prohibición expresa de tratar los datos para fines distintos al encargo.

1.5 Lugar de trabajo

La auditoría se ha llevado a cabo de forma presencial en las instalaciones centrales de **Motor Astur S.L.**, localizadas en la AVENIDA VIELLA, 40-33420. SIERO. El proceso de verificación técnica se desarrolló el **10 de mayo de 2026**.

Para la ejecución de este dictamen, se ha seguido un flujo metodológico estructurado en las siguientes fases:

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 16 de 20	

- **Identificación de interlocutores:** Entrevistas directas con el Gerente y los responsables de los departamentos de administración, ventas y postventa.
- **Inspección *in situ*:** Revisión física de las medidas de seguridad en el taller, zona de exposición y despachos.
- **Análisis de sistemas:** Evaluación de los controles de acceso lógico, protocolos de cifrado y gestión de copias de seguridad en el ERP "GestMotor 360".
- **Contraste documental:** Revisión de las políticas internas y contratos para verificar su adecuación al RGPD.

1.6 Documentación entregada

Para sustentar la opinión de la auditoría, se han recopilado y analizado las siguientes evidencias documentales y técnicas:

- **Registro de Actividades de Tratamiento (RAT):** Documento actualizado que sustituye la antigua inscripción de ficheros en la AEPD, detallando las actividades de Gestión de Clientes, RRHH, Videovigilancia y Gestión del catálogo online.
- **Contratos de Confidencialidad:** Copias de las cláusulas de confidencialidad firmadas por los empleados comerciales y del taller al incorporarse a la empresa.
- **Registros de Formación:** Listas de asistencia y temario del curso de formación inicial sobre protección de datos impartido al personal.
- **Contratos con Encargados de Tratamiento:** Copia de los contratos de prestación de servicios con "Consultoría Pérez" y "AsturWeb", en los que se ha constatado la *ausencia de cláusulas específicas* de protección de datos, constituyendo un incumplimiento objeto de medida correctora.
- **Política de Copias de Seguridad:** Capturas de pantalla de la configuración del sistema "GestMotor 360" y Azure que verifican los backups incrementales diarios y la copia completa semanal.
- **Evidencias de Control de Acceso:** Capturas de pantalla del sistema de gestión de usuarios del ERP que evidencian la existencia de un usuario genérico en el equipo comercial y la ausencia de política de contraseñas robusta.

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 17 de 20	

- **Certificaciones de Infraestructura:** Documentación técnica del proveedor (Microsoft Azure) confirmando la ubicación de los centros de datos en territorio de la Unión Europea.
- **Cartel Informativo de Videovigilancia:** Fotografía del distintivo informativo situado en las entradas de las instalaciones de Motor Astur S.L..

1.7 Conclusión

Tras la realización de la auditoría de cumplimiento del RGPD y del Reglamento de Medidas de Seguridad (R.D. 1720/2007) en Motor Astur S.L., se concluye que la organización presenta una base organizativa reconocible, con la existencia de un manual de protección de datos, formación inicial para parte del personal y procedimientos de backup, pero con deficiencias significativas que impiden afirmar un cumplimiento pleno de la normativa aplicable.

El grado de cumplimiento global se estima como parcial, con incumplimientos en áreas técnicas de especial relevancia para los ficheros de nivel medio que gestiona la empresa (datos financieros, bancarios y de nóminas).

Los principales riesgos detectados se agrupan en cuatro categorías:

Riesgos altos: La ausencia de registros de acceso (logs) al ERP para ficheros de nivel medio supone una vulneración directa del artículo 103 del RMS, impidiendo cualquier trazabilidad ante una brecha de seguridad. La falta de contratos de encargado de tratamiento con Consultoría Pérez y AsturWeb conforme al artículo 28 del RGPD expone a la empresa a una responsabilidad directa en caso de incidente con datos de empleados o clientes. El usuario genérico detectado en el equipo comercial imposibilita la identificación individual de accesos, incumpliendo los artículos 93 y 98 del RMS.

Riesgos medios: La ausencia de cifrado verificado en los formularios web expone los datos en tránsito a posibles interceptaciones. El registro de incidencias actual es insuficiente al no contemplar brechas de privacidad ni sus efectos, lo que compromete el cumplimiento del plazo de notificación de 72 horas a la AEPD previsto en el artículo 33 del RGPD.

Riesgos bajos: La falta de actualización del inventario de activos y del documento de seguridad, y la ausencia de formación específica para los mecánicos sobre datos de geolocalización y telemetría, representan deficiencias organizativas que deben subsanarse a corto plazo.

Aspectos positivos a destacar: la segmentación de la red mediante VLANs y WPA3, la autenticación nominal por usuario en el CRM para la mayoría del

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 18 de 20	

personal, la destrucción física de documentos mediante trituradora, el uso de portales B2B cifrados para el envío de documentación financiera a entidades de crédito, y el cumplimiento del plazo legal de conservación de imágenes de videovigilancia (30 días) son prácticas correctas que conviene mantener y documentar formalmente.

Como línea de actuación prioritaria se recomienda que Motor Astur S.L. aborde en primer lugar la formalización de los contratos de encargado de tratamiento, la activación del registro de accesos en el ERP y la eliminación del usuario genérico, dado que estos tres elementos presentan el mayor riesgo jurídico y técnico para la organización en el corto plazo. El resto de medidas correctoras descritas en los apartados anteriores deben integrarse en un plan de acción con responsables y plazos definidos, cuyo cumplimiento deberá verificarse en la próxima auditoría, que conforme al artículo 96 del RMS deberá realizarse en un plazo máximo de dos años.

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 19 de 20	



2. ANEXOS

2.1 Bibliografía

[1] Unión Europea. Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016. Disponible en: <https://eur-lex.europa.eu/legal-content/ES/TXT/?uri=CELEX%3A32016R0679>

[2] España. Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales. Disponible en: <https://www.boe.es/buscar/act.php?id=BOE-A-2018-16673>

[3] España. Real Decreto 1720/2007, de 21 de diciembre. Disponible en: <https://www.boe.es/buscar/act.php?id=BOE-A-2008-979>

[4] Agencia Española de Protección de Datos (AEPD). Guía de análisis de riesgos para el tratamiento de datos personales.

David Rodríguez Chanca, Javier Gutiérrez Esquinas, Carlos Cabrera Moral		
Escuela de Informática, Universidad de Oviedo	2025/26	ASLEPI
Auditoría Motor Astur S.L.	Página 20 de 20	